

## SlashAndGrab: The ConnectWise ScreenConnect Vulnerability Explained (CVE-2024-1709 / CVE-2024-1708)

ConnectWise ScreenConnect versions below 23.9.8 contain two critical vulnerabilities (CVE-2024-1709, CVSS 10.0, and CVE-2024-1708) allowing authentication bypass via a trivial path-traversal trick dubbed 'SlashAndGrab.' Huntress researchers built a proof-of-concept in under two hours and observed rapid in-the-wild exploitation within 48 hours, including ransomware drops, coin miners, and persistent remote access implants. Huntress responded by issuing 1,600+ incident reports to partners, publishing detection guidance, contributing Sigma rules to SigmaHQ, and deploying a proactive vaccine hotfix to vulnerable endpoints.

### Threat Actors Identified

| Actor                 | Aliases | Attribution Confidence |
|-----------------------|---------|------------------------|
| Unknown Threat Actors | —       | B2                     |

### Kill Chain Coverage

| Reconnaissance | Weaponization | Delivery | Exploitation | Installation | C2 | Actions |
|----------------|---------------|----------|--------------|--------------|----|---------|
|                |               |          | ✓            | ✓            | ✓  | ✓       |

### Techniques Observed (7)

|       |       |       |       |       |       |       |
|-------|-------|-------|-------|-------|-------|-------|
| T1190 | T1548 | T1083 | T1486 | T1496 | T1133 | T1078 |
|-------|-------|-------|-------|-------|-------|-------|

## Business Impact Assessment

---

### Financial Exposure

**\$0 - \$0**

### Operational Impact

Thousands of on-premises ScreenConnect servers were potentially exposed; successful exploitation grants full administrative control, enabling ransomware deployment, cryptomining, and persistent remote access that survives patching of the initial vulnerability.

### Regulatory Exposure

Organizations in regulated industries (healthcare, finance, government) may face breach notification obligations and compliance violations (HIPAA, PCI-DSS, GDPR) if sensitive data was accessed or exfiltrated via compromised ScreenConnect instances.

### Recommended Board Actions

- Immediately upgrade all on-premises ConnectWise ScreenConnect instances to version 23.9.8 or later and verify patch status across the entire managed estate, including endpoints managed by third-party MSPs.
- Commission an incident response review of all ScreenConnect servers that were unpatched between February 19–21, 2024, including forensic analysis for ransomware staging, coin miner artifacts, and unauthorized credential creation.
- Implement network segmentation and privileged access controls around remote management tooling, and require multi-factor authentication for all remote access solutions to reduce blast radius of future authentication bypass vulnerabilities.

## Sectors Targeted

---

Information Technology

Managed Service Providers

All sectors using ConnectWise ScreenConnect on-premises

## Indicators of Compromise

---

2 indicators extracted. Full IoC list available in the Tactical report or via `GET /v1/iocs`.